Attaque par Rebond (FTP): Très vieille attaque bloqué par défaut depuis 20 ans ! détourne la commande historique PORT et force le serveur ftp a "scanner" une cible interne de son réseau par exemple on peux réaliser cette attaque avec nmap

```
Agentpathogene@parrot ~$ nmap -Pn -v -n -p80 -b anonymous:password
10.10.110.213 172.17.0.2
<- - ->
80/tcp open http
```

Notons une vulnérabilité récente une path transversale avec écriture de fichier a
Exploitable : CVE-2022-22836

Attaquer SMB (Serveur Message Block):

SMB est un protocole de communication créé pour fournir un accès partagé à des fichiers et imprimantes entre les noeuds d'un réseau il utilise actuellement le port4
Samba est une implémentation open-source basé sur linux/Unix qui permet aux serveurs Unix et client windows d'utiliser les mêmes services SMB.
+ Un autre protocole souvent associé à SMB est MSRPC (Microsoft Remote Procedure Call) il fournit aux developpers d'application un moyen générique d'exécuter "du code" dans un processus local ou distant sans avoir a comprendre les protocoles réseaux utilisés pour prendre en charge la communication

Authentification null: Un serveur SMB peux être configuré pour s'autoriser les connexions sans utilisateur ni mot de pass dites (null-session) donnant accès à des informations et données sensibles

Appel de Procédure à distance RPC: Les RPC permettent à un programme sur un ordinateur d'exécuter une action précise à distance, les RPC "voyage" sur le réseau via SMB les commandes sont exécutées avec les "privilèges" des crédentials donné par le login SMB, les rpc sont souvent disable en null-session, certaines failles peuvent donc entrainées une RCE. L'outil rpcclient permet d'exécuter des RPC sur un serveur SMB, de recueillir des informations et modifier des attributs

```
Agentpathogene@parrot ~$ rpcclient -U "username%mdp" ip   (juste % pour null-auth)
rpcclient $> enumdomusers => enumère les utilisateur sur la machine ou dom
rpcclient $> enumdomgroups => pareil pour les groupes
rpcclient $> getdompwinfo => affiche la politique de mot de pass du domain
rpcclient $> netshareenumall => liste TOUT les dossiers partagés dispos sur le serveu
```

Brute Force + Pulvérisation: Les commandes ont déjà été vues dans le module Password Attaques mais avec de nombreux outils on peux tenter un brutforce du protocole SM

Execution de Code à Distance: Plusieurs outils nous permettent avec des accès administrateur d'exécuter des commandes sur un serveur SMB distant extraire des hashage SAM et faire du PtH, l'outil nxc ou NetExec permet tout cela...

Attaque par authentification forcée: consiste a tenter de piéger une machine pour tenter de la forcée à se connecter à une machine controlé par l'attaquant via SM
Par défault si Windows croit qu'il doit récuperer un fichier sur un partage réseau il va automatiquement envoyé au serveur les username et hash NTLM de session en cours pour prouver son identité.

① L'attaquant lance un outil d'écoute sur sa propre machine qui se fais passer pour un serveur SMB légitime en attente de connexion, le meilleur est responder

```
Agentpathogene@parrot ~$ sudo responder -I nomInterfaceReseauExiens3
```